

Context-Aware Agentic AI Framework for Automated VAPT

Phase Review handout · generated 2026-09-18 19:46 · fully local: CPU embeddings, ChromaDB, local LLM — no cloud, no API keys

Thesis: feeding organizational context (asset criticality, network topology, security policy) into an agentic VAPT pipeline changes agent behavior **measurably** — proven by an ablation study running the same agent with context (aware) and without (blind).

1 · Architecture — the agent loop



Safety: probing is hard-guarded to RFC1918/documentation ranges (critical audit check, weight 0.20), TCP-connect only, 5-port footprint; bug-bounty scope (RFC 9116 security.txt) can only *restrict*, never enable.

2 · Verified results (live captures, this build)

Area	Metric	Aware	Blind	Meaning
Retrieval	A1 context hit rate	1.00	—	RAG answers for every target
Planning	B2 plan recall (expert)	1.000	0.833	context finds the right ports (1433 fix)
Planning	B4 context sensitivity	1.00	—	plans change with context
Ablation	R2 recall delta	+0.167	—	the thesis, quantified
Prioritization	M1 rank correlation ρ	+1.00	-0.90	$\Delta\rho = +1.90$ vs expert ground truth
Prioritization	M2 dead-end recall	100%	0%	firewall-blocked paths caught
Prioritization	M3 alert-fatigue relief	75%	—	false-critical alerts demoted
Audit	recon_quality_score	98.1/100	control	grade A, PASS, zero failed checks
Engineering	test suite	190 passed	—	fully offline, ~35 s

3 · The evaluation loop working — before/after

	Before fix	After fix
Audit score	94.5 (1 failed check: Q6 expert recall)	98.1 (zero failed checks)
Plan recall (B2)	0.833 — MSSQL/1433 missed on HR database	1.000 — hint table extended
Ablation signal (R2)	0.000 (no divergence)	+0.167 (context finds what blind misses)

The auditor *found* the planner gap, the fix was made, the metrics *proved* the improvement — the evaluation pipeline functioning as designed.

4 · Honest limitations (stated before you ask)

- C2–C4 (port-state accuracy) need a live lab — testbed hosts are down, so those metrics report *n/a*, never fake 1.0s.
- TCP-connect probes only — no service fingerprinting or exploitation yet (Phase 3).
- Single flat Chroma collection; dense retrieval only (no rerank/BM25).
- Ablation statistical protocol (≥ 10 scenarios, Wilcoxon) is defined but awaits the lab.

5 · Reproduce everything

```
$ python scripts/rag_query.py "What are the compliance requirements for payment systems?"
$ python scripts/run_recon.py
$ python scripts/run_eval_agent.py --ground-truth results/ground_truth_testbed.json --llm
$ python scripts/run_context_agent.py && python scripts/eval_context.py
```

```
$ pytest tests/ -v # 190 tests, offline
```